

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – CASE STUDY

COURSE CODE: ITA1408

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

C04: *Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)*

Assessment Tool Weightage: 35%

Code of Conduct:

I P.Ranjithkumar (192411119) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:Prky

QUESTIONS: 5

Total Marks:100

-
1. A mid-sized e-commerce company hosts its web application on an Apache server running on a Linux environment. Recently, customers reported unauthorized transactions and abnormal account activities. Upon investigation, the IT team discovered suspicious HTTP requests in server logs, including attempts to access hidden directories and injection of malicious scripts into input fields. Additionally, the server is running an outdated version with known vulnerabilities, and no Web Application Firewall (WAF) is implemented. As a cybersecurity analyst, you are tasked with conducting a comprehensive security assessment using Kali Linux. Analyze the possible attack vectors exploited by the attacker, including web server vulnerabilities, input validation issues, and outdated software components. Explain in detail how you would perform reconnaissance, vulnerability scanning, and exploitation using appropriate Kali Linux tools. Further, propose a layered defense strategy that includes server hardening, secure coding practices, and network-level protections to prevent such incidents in the future.
 2. A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web

pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this scenario. Describe a step-by-step methodology using Kali Linux tools such as Burp Suite and SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies, including input validation, output encoding, secure session handling, and implementation of security controls.

3. A corporate office provides wireless internet access to employees using WPA2-PSK authentication. Recently, several employees reported unusual login prompts and slow network performance. A security investigation revealed the presence of a rogue access point (Evil Twin) mimicking the official network SSID. Attackers used this setup to capture login credentials and perform man-in-the-middle (MITM) attacks. You are tasked with analyzing the breach and strengthening wireless security. Explain how the attacker successfully executed the Evil Twin attack and intercepted sensitive data. Describe how Kali Linux tools such as Aircrack-ng and Wireshark can be used to detect and analyze such attacks. Evaluate the weaknesses in the existing wireless security configuration. Propose robust countermeasures, including secure authentication mechanisms, network monitoring, and user awareness strategies.

4. An organization's internal network hosts a web-based employee management system accessible over Wi-Fi. The wireless network uses weak passwords, and the web application lacks proper authentication and session management. An attacker gains access to the Wi-Fi network, performs reconnaissance, and exploits vulnerabilities in the web application to escalate privileges and access confidential employee data. You are assigned to perform a full penetration testing assessment. Analyze the attack chain starting from wireless network compromise to web application exploitation. Describe each phase of the attack, including reconnaissance, scanning, exploitation, and privilege escalation. Demonstrate how Kali Linux tools can be used in each phase. Propose a comprehensive security framework that addresses both wireless and web application vulnerabilities, ensuring defense-in-depth.
5. A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation reveals repeated deauthentication attacks targeting access points, causing legitimate users to disconnect. The attacker uses automated tools to continuously send deauth packets, leading to denial of service. You are tasked with identifying the cause and implementing solutions. Explain how deauthentication attacks are carried out in wireless networks and how attackers exploit protocol weaknesses. Describe how Kali Linux tools can be used to simulate and analyze such attacks in a controlled environment. Evaluate the impact on network availability and user productivity. Recommend effective mitigation strategies, including network configuration changes, intrusion detection systems, and secure wireless

protocols.

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Case	25	Thorough understanding; clearly identifies all key issues	Good understanding with most issues identified	Basic understanding; some issues missed	Poor understanding; problem not identified correctly
Application of Concepts	25	Effectively applies relevant concepts to analyze the case deeply	Applies appropriate concepts with minor gaps	Limited application of concepts	Fails to apply relevant concepts
Analysis	20	In-depth analysis with strong reasoning and insights	Good analysis with logical reasoning	Basic analysis with limited depth	Weak or no analysis; lacks reasoning
Solution Design	20	Innovative, feasible solutions with strong justification	Logical solutions with adequate justification	Basic solutions with weak justification	Incorrect or no solution provided
Clarity	10	Clear, well-structured, and easy to understand	Organized and understandable presentation	Limited clarity and structure	Poor clarity difficult to understand

1) Security Assessment of an E-Commerce Web Application

Introduction

The e-commerce application is hosted on an outdated Apache server running Linux. Unauthorized transactions, abnormal account activities, suspicious HTTP requests, directory traversal attempts, malicious scripts, and injection attempts indicate possible web server and web-application vulnerabilities. A comprehensive security assessment should therefore be performed using Kali Linux.

1) Reconnaissance

The first phase is to identify the target's network and services

whois example.com

nslookup example.com

dig example.com

nmap -eV -O <AUTHORIZED_IP>

2) Vulnerability Scanning

Tools such as Nmap, Nikto, and OpenVAS/Greenbone can be used to identify outdated software, insecure configuration and exposed services

nikto -h http://<LAB_IP>

nmap --script vuln <AUTHORIZED_IP>

3) Web Application Testing

The suspicious requests indicate possible directory traversal, SQL injection, Command injection, and XSS. Burp Suite can be used to intercept HTTP requests and examine parameters, cookies, headers, and responses.

4) Exploitation validation

Any vulnerability discovered should be validated only against a dedicated test system. The objective is to prove the vulnerability without modifying or stealing real customer data.

5) Defense Strategy

The company should:

- upgrade Apache and Linux packages regularly.
- Remove unnecessary services and directories.
- Apply secure file permissions.
- validate and sanitize all user input.
- use parameterized SQL queries.

Conclusion:

The incident appears to involve weaknesses at both the web-application and server levels. Combining reconnaissance, vulnerability scanning, controlled validation, server hardening, secure coding, WAF protection, and continuous monitoring can significantly reduce the possibility of future attacks.

2) SQL Injection and XSS Security Audit

Introduction:

The financial application contains sensitive customer and transaction information. SQL Injection can allow attackers to manipulate database queries, while cross-site scripting (XSS) can execute malicious browser-side scripts. Both vulnerabilities can seriously affect confidentiality integrity and availability.

1) Reconnaissance

First identify the application's attack surface and technologies.

```
nmap -sV <AUTHORIZED-IP>  
nikto -h http://<LAB-Host>
```

Burp Suite can then be configured as a proxy to capture requests generated by the application.

2) Testing with Burp Suite

The tester should examine,

- Login forms
- Search fields
- Account numbers
- URL parameters
- Transaction parameters

The captured requests can be sent to Repeater to safely modify one parameter at a time and observe the response.

3) SQL Injection Testing

SQL injection occurs when untrusted input becomes part of a database query. Signs include database errors, unexpected results, authentication by pass behavior, or differences b/w normal and manipulated requests.

Sqlmap -u

"http://LAB_HOST/item?id=1" --batch

4) XSS Testing

XSS occurs when application input is returned to a user's browser without proper encoding. Burp Suite can be used to identify parameters that reflect user input. A harmless test string can be used in laboratory.

5) CIA Impact

Security property

Impact

Confidentiality

Customer and financial information may be exposed

Integrity

Unauthorized modification of records may occur

Availability

Database or application resources may be disrupted

Conclusion

SQL Injection primarily threatens database security, while XSS mainly affects application users and sessions. Secure coding, parameterized queries, input validation, output encoding, secure sessions, and continuous security testing are essential for protecting a financial application.

3) WPA2-PSK Evil Twin and MITM Attack

Introduction:

The corporate wireless network uses WPA2-PSK authentication. Attackers have created a rogue access point that imitates the legitimate SSID. This is known as an Evil Twin attack. Users connecting to the fake network may expose credentials or sensitive traffic to the attacker.

1) Wireless Reconnaissance

In an authorized laboratory, Kali Linux wireless tools can identify nearby access points and their characteristics.

`iwconfig`

`airmon-ng`

`airodump-ng <monitor-interface>`

2) Detecting the Evil Twin

The fake AP may use the same SSID as the legitimate network but have a different BSSID.

Indicators include:

- same SSID with different BSSID
- unexpected signal strength
- unknown access-point hardware
- unusual DHCP/DNS behavior

3) Wireshark Analysis

Wireshark can help analyze traffic captured during the authorized peer

```
wlan
wlan.fc.type == 2
dns
http
```


4) Understanding MITM

After a victim connects to a rogue AP, the attacker may attempt to position themselves b/w the victim and the legitimate network. unencrypted traffic can then potentially be observed or manipulated.

5) Countermeasures

The organization should implement:

- WPA3 - Enterprise where possible
- 802.1X authentication
- Strong, unique wireless credentials
- Certificate-based authentication
- Regular wireless security assessments

6) User Awareness

Employees should be trained not to connect to unknown networks simply because the SSID looks familiar. They should report certificate warnings, unexpected login pages and repeated wifi authentication problems.

Conclusion:

An Evil Twin attack exploits user trust in a familiar SSID. Strong enterprise authentication, wireless monitoring, certificate validation, network segmentation, and employee awareness provide effective protection against rogue access points and MITM attacks.

4) Wireless Network to web Application Attack chain

Introduction:

The organization has a wi-fi network protected only by passwords, while its employee-management web application has weak authentication and session management. An attacker who compromises the wireless network may use it as an entry point to reach the web application and eventually access confidential employee information.

1) Wireless Reconnaissance

The authorized tester first identifies wireless networks and their security configuration.

`iwconfig`

`airmon-ng`

`airodump-ng <monitor-interface>`

2) Network Enumeration

After obtaining authorized network access, the tester can identify hosts and services.

`ip addr`

`ip route`

`nmap -sn <AUTHORIZED-SUBNET>`

`nmap -sV <AUTHORIZED-IP>`

3) web Application scanning

Tools such as Nikto, Gobuster, and Burp suite can be used to identify application weaknesses

`nikto -h http://<LAB-HOST>`

`gobuster dir -u http://<LAB-HOST> /
-w /usr/share/wordlists/dirb/
common.txt`

4) Exploitation and Privilege Escalation

potential weaknesses may include:

- weak authentication
- session fixation
- predictable session tokens
- Broken Access Control
- excessive privileges

5) Defense-in-Depth

- Wireless Security
- Network Security
- Application Security

6) Monitoring

Security teams should continuously monitor

- failed login attempts
- unusual session activity
- New devices
- Access to sensitive employee records

Conclusion:

A wireless compromise can become the first stage of a larger attack chain. Therefore, security should not depend on a single control. Strong Wi-Fi authentication, network segmentation, secure application development, access control, monitoring and incident response together provide effective defense-in-depth.

5) Wireless Deauthentication Attacks And Dos

Introduction:

The university is experiencing wi-fi interruptions during peak hours. Investigation indicates repeated deauthentication attacks. A deauthentication attack abuses wireless management-frame behavior to force legitimate clients to disconnect from an access point, resulting in Denial of Service (Dos).

1) Cause of the Attack

In traditional wi-fi networks management frames were historically not strongly protected. An attacker with suitable wireless equipment can generate forged management traffic that causes clients to disconnect.

- Repeated disconnections
- Failed reconnections
- Reduced network availability
- Increased authentication traffic.

2) Kali Linux Analysis

In an authorized laboratory, Kali Linux can be used to analyze wireless traffic.

```
iwconfig  
airmon-ng  
airodump-ng <monitor-interface>
```

3) Controlled Simulation

for security testing, the attack should be simulated only on an isolated test AP and test devices. The objective is to confirm whether monitoring systems detect abnormal deauthentication traffic rather than disrupting a real campus network.

4) Impact

A successful continuous deauthentication attack can cause,

- Loss of network availability
- Interrupted online classes
- Disconnected legitimate users
- potential disruption of important services

Conclusion.

Deauthentication attacks mainly target network availability. Continuous wireless monitoring centered management frameworks, WPA3/enterprise authentication, 802.11p, updated access points and proper incident response procedures can greatly reduce the impact of these attacks.